

POLICY SUMMARY

GARIL AI

Information Security Policy Summary

Organisational & product security principles

Version	1.0
Date	3 October 2026
Audience	Partner universities & institutional stakeholders
Classification	Confidential — authorised institutional use

Important notice

Summary of security principles for partner institutions. Detailed runbooks remain internal. Production configuration obligations for hosts are listed in Section 5.

1. Policy objective

Protect the confidentiality, integrity, and availability of university and user data processed by GARIL AI, and ensure responsible use of AI features within institutional governance.

2. Scope

- GARIL AI web application, API, databases, and optional object storage
- Administrative and portal users (students, supervisors, university admins, platform admins)
- Subprocessors used for hosting, email, and AI inference

3. Principles

- Least privilege — role and university scoping for administrative access
- Defence in depth — authN/authZ, rate limits, headers, sanitisation, audit
- Secure by default — default-deny APIs; opt-in bootstrap admin; no weak hardcoded secrets
- Privacy by design — ownership filters, retention/deletion tooling, non-enumerating password reset
- Accountability — audit logs for sensitive admin actions; AI use telemetry where enabled

4. Access management

- Unique user accounts; strong passwords (minimum 10 characters with letter and number)
- Session tokens expire (24 hours); inactive accounts cannot use the API
- Platform backups and break-glass data exports limited to super administrators
- University administrators manage only their institution's tenancy

5. Production obligations (operator / host)

- Unique AUTH_SECRET; CORS_ORIGIN allowlist; TLS at the edge
- Disable DEFAULT_ADMIN_ENABLED after first bootstrap; rotate bootstrap credentials
- Keep application nodes private behind a reverse proxy
- Keep object-storage buckets private; apply institutional backup encryption/retention
- Monitor auth failures, uptime, and AI spend

6. Acceptable use (summary)

Users must not attempt to bypass access controls, exfiltrate others' data, or use the AI features for unlawful content. Full AI Acceptable Use is defined in the AI Governance PDF.

7. Review

This policy summary is reviewed after material product security changes and at least annually. Last security audit remediation: October 2026.